Threat Intelligence Brief: Scattered Spider

TLP:CLEAR (open-source reporting) | **Date:** October 21, 2026 | **Prepared by:** OKUNNUWA JOSHUA GODWIN

Aliases: UNC3944, Octo Tempest, Storm-0875, 0ktapus, Muddled Libra | **MITRE ATT&CK:** G1015 | **Motivation:** Financial (data theft, extortion, ransomware)

Bottom Line

Scattered Spider gets in by phoning the IT help desk, posing as an employee, and getting passwords and MFA reset. They then log in with real credentials and use legitimate admin tools, so they are hard to spot. Since 2023 they have hit casinos, retailers, insurers, airlines and transit. Several core members are now in custody or have pleaded guilty, but the methods are easy to copy and remain a live threat.

Actor Profile

A loose group of mostly young, native English speakers that grew out of a cybercrime community known as The Com, active since at least 2022. CISA and the FBI say it targets large companies and their contracted IT help desks (AA23-320A). Members hand access to ransomware partners, including BlackCat/ALPHV (2023) and DragonForce (2025). A DOJ indictment alleges over 100 victims and at least $115 million in ransoms. Since 2025 the group has worked with ShinyHunters and Lapsus$ as "Scattered Lapsus$ Hunters."

Key Incidents

Date	Victim	Detail
Sept 2023	MGM Resorts, Caesars	Help desk social engineering, outages, data theft
Aug 2024	Transport for London	Disruptive intrusion; two members pleaded guilty in June 2026
Apr 2025	Marks & Spencer	Help desk impersonation, ransomware handoff
Sept 2025	Jaguar Land Rover	Attributed to the merged collective; production halted for weeks

How They Operate

1. **Access:** voice phishing of help desks, SMS phishing with lookalike login pages, SIM swapping, MFA fatigue, and session token theft.
2. **Persistence:** new accounts, attacker-owned MFA devices, and legitimate remote tools such as Atera.
3. **Evasion:** disabling security tools and joining incident response calls to watch defenders.
4. **Impact:** staging and cloud exfiltration, then ransomware on VMware ESXi hosts when encryption is the goal.

Tools reported: Atera, Raccoon Stealer, Spectre RAT, partner ransomware.

MITRE ATT&CK Mapping

Source: MITRE G1015 and CISA AA23-320A (ATT&CK v17).

Tactic	Technique	Observed behavior
Reconnaissance	T1598.004 Spearphishing Voice	Calling help desks for account details
Resource Development	T1583.001 Domains	Lookalike corporate login portals
Initial Access	T1566.002 Spearphishing Link	Phishing kits, fake SSO pages
Initial Access	T1451 SIM Card Swap	Taking over numbers to catch MFA codes

Tactic	Technique	Observed behavior
Initial Access	T1078 Valid Accounts	Stolen or reset credentials
Credential Access	T1621 MFA Request Generation	Repeated push prompts
Credential Access	T1539 Steal Web Session Cookie	Token theft to skip MFA
Persistence	T1136 Create Account	New identities in the victim network
Persistence	T1556.006 Modify Auth Process: MFA	Enrolling attacker MFA devices
Defense Evasion	T1562.001 Disable or Modify Tools	Removing security software
Defense Evasion	T1656 Impersonation	Posing as staff and IT
Command and Control	T1219 Remote Access Software	Legitimate tools as backdoors
Exfiltration	T1567.002 Exfiltration to Cloud Storage	Data moved to cloud services
Impact	T1486 Data Encrypted for Impact	BlackCat/ALPHV, DragonForce

Status and Confidence

Tyler Buchanan pleaded guilty in the US (April 2026), and Thalha Jubair and Owen Flowers pleaded guilty in the UK (June 2026). ShinyHunters has kept breaching large firms. Confidence is high on TTPs, since multiple government and vendor sources agree, and moderate on current membership, because the group is fluid and its Telegram claims are unreliable.

Detection and Defense

- Alert on a password or MFA reset followed by a new device enrollment within hours.
- Flag new remote access tools, security agent removal, and bulk cloud downloads.
- Require phishing-resistant MFA (FIDO2) for staff and admins.
- Verify help desk callers by call-back to a known number or manager approval, with no exceptions.
- Allowlist remote tools, keep offline backups of ESXi hosts, and plan out-of-band incident communications.

Sources

1. CISA/FBI, AA23-320A Scattered Spider (updated July 2025): https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-320a
2. MITRE ATT&CK, G1015: https://attack.mitre.org/groups/G1015/
3. Picus Security, Tracking Scattered Spider (July 2025): https://www.picussecurity.com/resource/blog/tracking-scattered-spider-through-identity-attacks-and-token-theft
4. KrebsOnSecurity, Scattered Spider coverage: https://krebsonsecurity.com/tag/scattered-spider/
5. DarkOwl, Scattered Lapsus$ Hunters (Jan 2026): https://www.darkowl.com/blog-content/threat-actor-spotlight-scattered-lapsus-hunters/